A3-PS002-TC273

Anushka Chaturvedi personal id-
anushkach1718@gmail.com
Aakriti Sharma personal id-
aakritisharma72008@gmail.com
AIORI Hackathon 3
October 5, 2026

Problem Description

In today's digital world, organizations collect and share users' personal data for various purposes, such as providing services, processing information, and sharing data with third-party applications. Data protection regulations, including India's Digital Personal Data Protection (DPDP) Act and the GDPR, emphasize that personal data should be processed only for specified purposes and that users must be able to withdraw their consent.

However, many systems record user consent in databases but fail to enforce consent decisions across all connected services. As a result, data may continue to be accessed or shared even after a user withdraws permission or changes their preferences.

The objective of this problem statement is to develop a prototype of a Purpose-Based Consent Management System that records, tracks, and enforces user consent in real time for a synthetic service.

Background

Digital services collect and share personal data for various purposes. Data protection regulations, such as India's DPDP Act and GDPR, emphasize user consent and control over personal information. However, many systems fail to update consent changes across connected services, allowing data access even after consent is withdrawn.

The proposed solution introduces a purpose-based consent management system that records user permissions, verifies consent in real time through a mock API, blocks unauthorized requests, and maintains audit logs for transparency and accountability.

Literature & RFC Review

- **DPDP Act, 2023 (India):** Establishes the legal context for consent, purpose limitation, and withdrawal of consent.
- **GDPR Article 7:** Addresses valid consent, proof of consent, and the right to withdraw consent.
- **ISO/IEC 27560:2023:** Provides guidance on structuring consent records and maintaining consent evidence.
- **RFC 7009:** OAuth 2.0 Token Revocation: Explains how authorization tokens can be revoked to prevent continued access using revoked tokens.
- **RFC 7662:** OAuth 2.0 Token Introspection: Defines how APIs can verify token status before authorizing access.

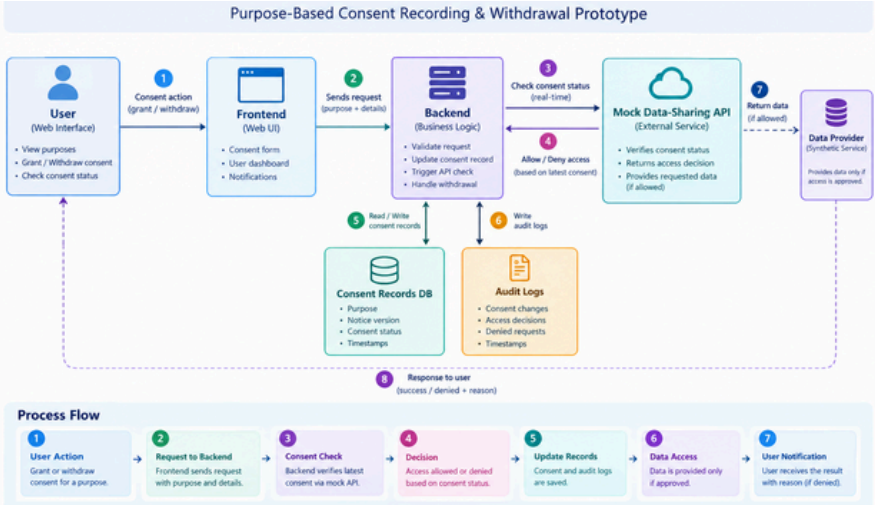
Proposed Solution

- **User Interface:** Simple dashboard to grant or withdraw consent for three data-sharing purposes.
- **Consent Records:** Store selected purpose, privacy notice version, consent status, and timestamps.
- **Mock Data-Sharing API:** Verify the latest consent status before allowing or denying each data-access request.
- **Withdrawal Enforcement:** Block requests when consent has been withdrawn.
- Audit Logs: Record consent changes, access decisions, and denied requests.
- **Scenario Testing:** Demonstrate consent granting, withdrawal, privacy notice updates, and unauthorized access prevention through lifecycle tests..

Optimization Proposed

Aspect.	Before (Existing Systems).	After (Proposed Solution)
Consent Management.	General or static consent records.	Purpose-specific consent controls
Consent Withdrawal.	Updates may not immediately. affect access.	Withdrawn consent blocks subsequent requests
Data Access.	Permissions may rely on outdated. records.	API checks the latest consent status
Privacy Notices.	Notice versions may not be tracked.	Version recorded with each consent decision
Auditability.	Limited visibility into access decisions.	Logs record consent changes and access results
Security.	Unauthorized requests may go unchecked.	Requests without valid consent are denied
Testing.	Limited consent lifecycle validation.	Tests cover grants, withdrawals, and notice changes

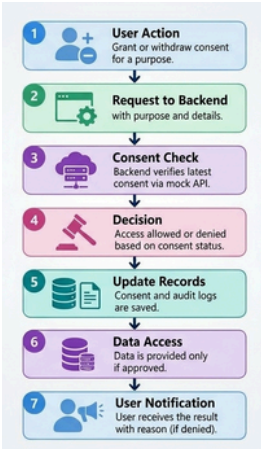
Solution Architecture & Design



Data Flow Diagram

Overview of the architecture:

- End-to-End Workflow: Illustrates how user consent actions flow from the web interface through frontend and backend systems to real-time verification and automated data access.
- Real-Time Verification: Integrates a Mock Data-Sharing API to instantly evaluate consent status and authorize or deny data requests.
- Dual Database Layer: Maintains separate databases for operational Consent Records (status, purpose, notice version) and immutable Audit Logs for auditability.
- 7-Step Linear Process: Maps complete user journeys—from initial user action and backend request to real-time decision-making, log updates, and instant user notification.
- Regulatory Compliance: Designed to enforce key DPDP & GDPR principles, prioritizing security, transparency, and user control.



Deployment Timeline

Proposed Duration: 7 Days

Timeline	Milestone	Key Activities
Day 1	Planning & Design	Finalize requirements, consent workflow, and UI design.
Day 2	Frontend Development	Build the consent dashboard and grant/withdraw controls.
Day 3	Backend Development	Implement consent management and API endpoints.
Day 4	Database & Audit Logs	Store consent status, purpose, notice version, and audit records.
Day 5	API Integration	Connect the mock data-sharing API for real-time consent verification.
Day 6	Testing & Validation	Test consent grants, withdrawals, notice changes, and unauthorized requests with at least 12 test cases.
Day 7	Deployment & Demonstration	Deploy the prototype, fix critical issues, and prepare the demo and documentation.

Deployment Methodology

- **Agile Development:** Build the prototype in small, manageable stages.
- **Continuous Integration:** Integrate and test frontend and backend components regularly.
- **Security Testing:** Verify that requests without valid consent are denied.
- **Final Validation**: Demonstrate the complete workflow and submit the source code, documentation, and test results.

Bibliography I

[1] Albert Einstein. “Ist die Trägheit eines Körpers von seinem Energieinhalt abhängig?” In: *Annalen der Physik* 323.13 (1905), pp. 639–641.

[2] Bert J. Tolkamp et al. “Are cows more likely to lie down the longer they stand?” In: *Applied Animal Behaviour Science* 124.1-2 (2010), pp. 1–10.

Thank You for Your Attention!